Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and Authorization.

Integrate Zscaler With Identity Providers(Idps)Such As Azure Ad,Okta,And Active Directory For Seamless Authentication And Authorization.

College name: TIRUPPUR KUMARAN COLLEGE FOR WOMEN

College code: bru3j

TEAM ID: SWTID-2026-3275

TEAM MEMBERS:

Team LeaderName: Princy Navera.N

Email: princynaverar@gmail.com

Team Member: Sowmya.T

Email: sowmyathangavel1511@gmail.com

Team Member: Sree Mathi.S

Email: saranvani83@gmail.com

Team Member: Navashree.G

Email: krishnangopal47160@gmail.com

Project Details

Title: Integrate Zscaler With Identity Providers(Idps)Such As Azure Ad,Okta,And Active Directory For Seamless Authentication And Authorization.

Project Overview:

This project outlines the strategy and implementation plan for integrating the Zscaler security platform with our organization's core Identity Providers (IdPs): Microsoft Entra ID (Azure AD), Okta, and on-premises Active Directory (AD). The primary objective is to create a seamless, secure, and automated framework for user authentication and authorization across all Zscaler services. By moving away from disparate local user management and leveraging these centralized identity sources, we aim to establish a true Zero Trust architecture where access is continuously verified based on user identity and context. This initiative will consolidate authentication into a single source of truth, enforce consistent security policies like Multi-Factor Authentication (MFA), and streamline the user experience through Single Sign-On (SSO). Ultimately, this integration will serve as the critical link between our identity infrastructure and our security enforcement point, ensuring that the right users have the right level of secure access to the internet and applications, regardless of their location..

Abstract

This project details the integration of the Zscaler Internet security platform with leading Identity Providers (IdPs), including Microsoft Entra ID (Azure AD), Okta, and on-premises Active Directory (AD). The primary objective is to establish a unified identity framework that enables seamless Single Sign-On (SSO) and centralized authorization for all Zscaler services. By consolidating authentication into trusted corporate directories, this initiative eliminates the need for disparate credentials and provides a foundational element for a modern Zero Trust security architecture. By leveraging industry-standard protocols such as SAML, OIDC, and SCIM, this integration ensures that user authentication is delegated to trusted corporate directories while enforcing consistent security policies, including Multi-Factor Authentication (MFA). This approach not only enhances the user experience by reducing password fatigue but also strengthens the organization's security posture by ensuring that every access request is verified by the identity provider before reaching Zscaler's security enforcement points. Furthermore, the implementation of automated user provisioning via SCIM streamlines lifecycle management, reducing administrative overhead and enhancing security posture. The outcome is a robust, identity-centric security model that aligns with Zero Trust principles, ensuring that only authenticated and authorized users gain secure access to internet and cloud applications from any location. This integration effectively bridges the gap between identity governance and network security, creating a dynamic and responsive access control environment..

Use Case Scenarios:

Secure Remote Employee Access

Employees working from home or remote locations can securely access internal company applications through Zscaler ZTNA. Instead of using traditional VPNs, users authenticate through identity verification and are granted access only to the specific applications they are authorized to use.

Third-PartyVendorAccessControl

Organizations often allow external vendors or contractors to access certain internal systems. Using ZTNA with Zscaler, vendors can be given limited, application-level access without exposing the entire network, reducing the risk of unauthorized access.

Secure Access for BYOD (Bring Your Own Device)

Employees using personal devices such as laptops or smartphones can securely connect to company applications. Zscaler verifies device security status and user identity before allowing access, ensuring that only trusted devices can connect.

Protection of Internal Applications

Sensitive internal applications such as HR systems, finance systems, or databases can be protected by ZTNA. Only authenticated and authorized users are allowed to access these applications, preventing direct exposure to the internet.

Threat Prevention and Monitoring

Zscaler continuously monitors network traffic and user activity. If suspicious behavior or potential threats are detected, access can be restricted immediately, helping organizations prevent cyberattacks and data breaches.

STAGE-1

Title Of the Project: Integrate Zscaler With Identity Providers(Idps)Such As Azure Ad,Okta,And Active Directory For Seamless Authentication And Authorization

Project Overview

This project outlines the strategy and implementation plan for integrating the Zscaler security platform with our organization's core Identity Providers (IdPs): Microsoft Entra ID (Azure AD), Okta, and on-premises Active Directory (AD). The primary objective is to create a seamless, secure, and automated framework for user authentication and authorization across all Zscaler services. By moving away from disparate local user management and leveraging these centralized identity sources, we aim to establish a true Zero Trust architecture where access is continuously verified based on user identity and context. This initiative will consolidate authentication into a single source of truth, enforce consistent security policies like Multi-Factor Authentication (MFA), and streamline the user experience through Single Sign-On (SSO). Ultimately, this integration will serve as the critical link between our identity infrastructure and our security enforcement point, ensuring that the right users have the right level of secure access to the internet and applications, regardless of their location.

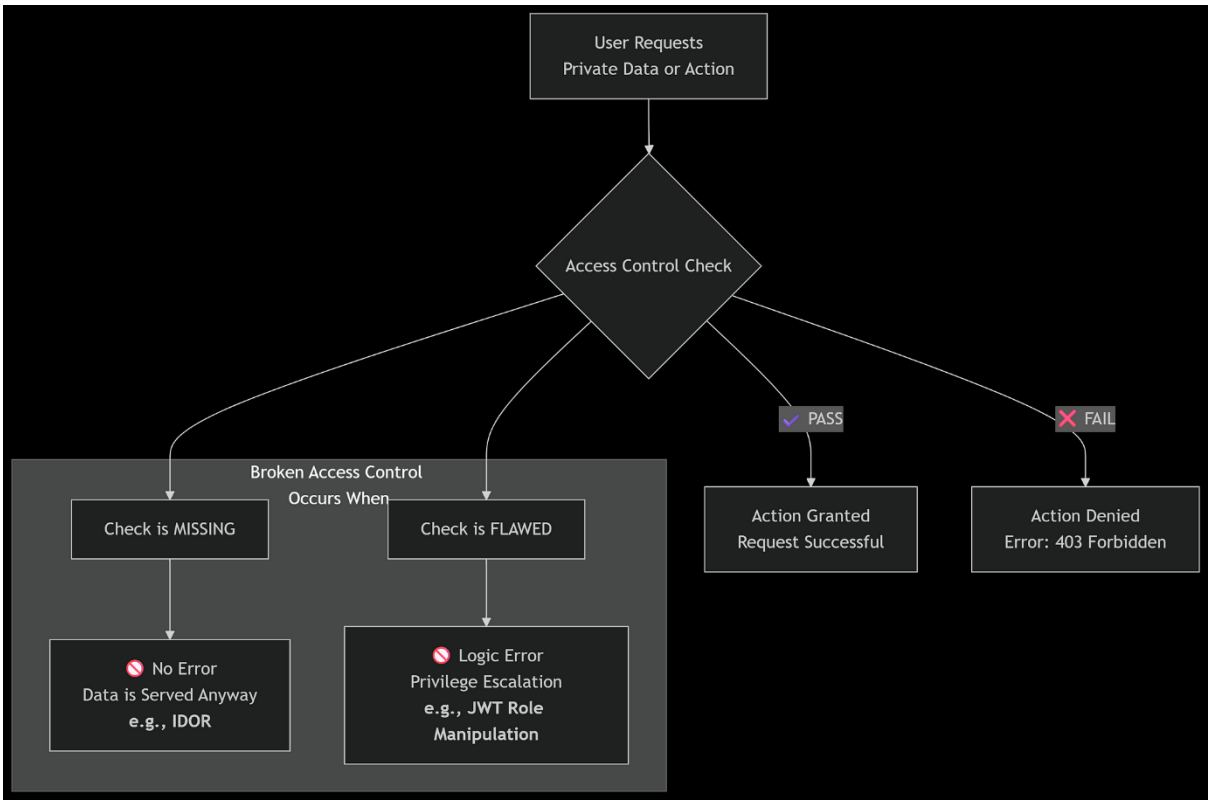
List of Vulnerability Table:

S.no	Vulnerability Name	CWE - No
1	Improper Authentication	CWE-287
2	Improper Access Control	CWE-284
3	Use of Hard-coded Credentials	CWE-798
4	Insufficient Session Expiration	CWE-613
5	Improper Certificate Validation	CWE-295
6	Missing Authentication for Critical Function	CWE-306
7	Exposure of Sensitive Information	CWE-200
8	Improper Logging and Monitoring	CWE-778
9	Insufficient Authorization	CWE-862
10	Improper Input Validation	CWE-20

REPORT: -

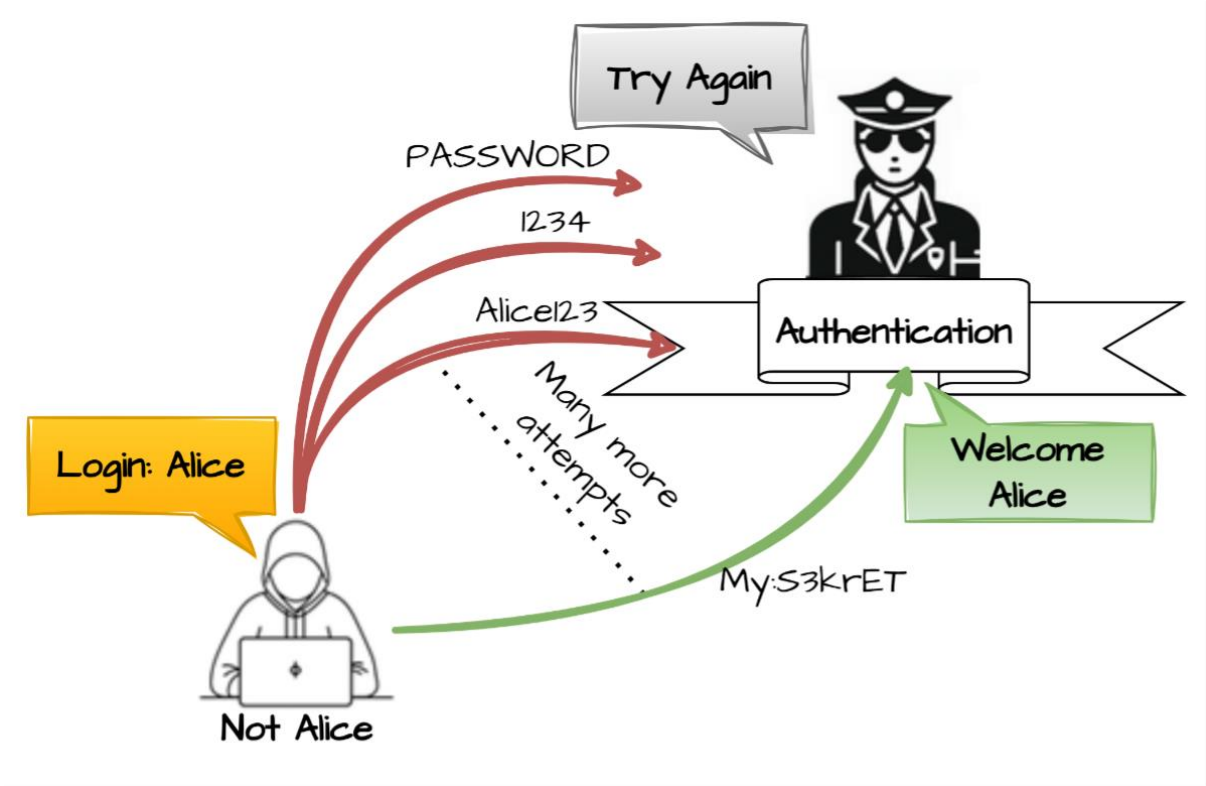
1) Vulnerability Name: Improper Access Control
CWE-284
OWASP Category: A01:2021 – Broken Access Control
Description: The system does not properly enforce restrictions on what authenticated users are allowed to do.
Business Impact: Unauthorized users may access sensitive applications or modify critical data.
Steps to Reproduce:

1. Log in with a low-privileged user account.
2. Attempt to access restricted resources or admin pages.
3. The system allows access without proper permission checks.



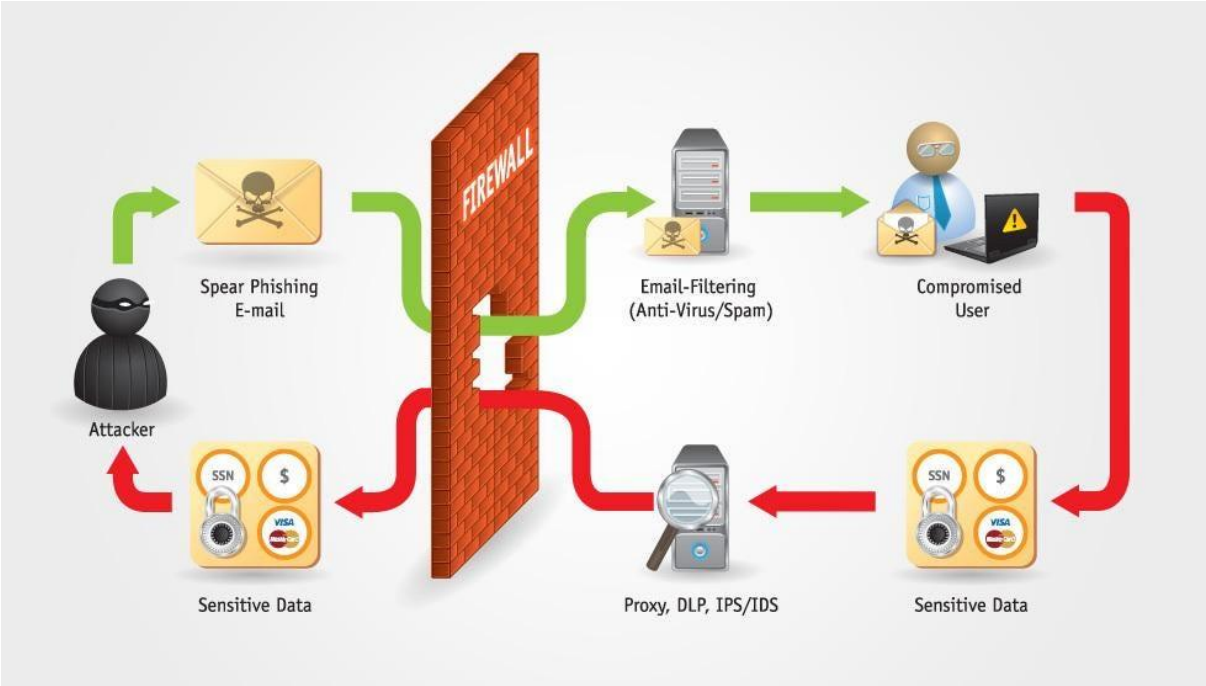
2) Vulnerability Name: Improper Authentication
CWE-287
OWASP Category: A07:2021 – Identification and Authentication Failures
Description: The application fails to correctly verify the identity of users before granting access.
Business Impact: Attackers can gain unauthorized access to internal systems.
Steps to Reproduce:

1. Attempt login using weak credentials.
2. System allows authentication without strong verification.



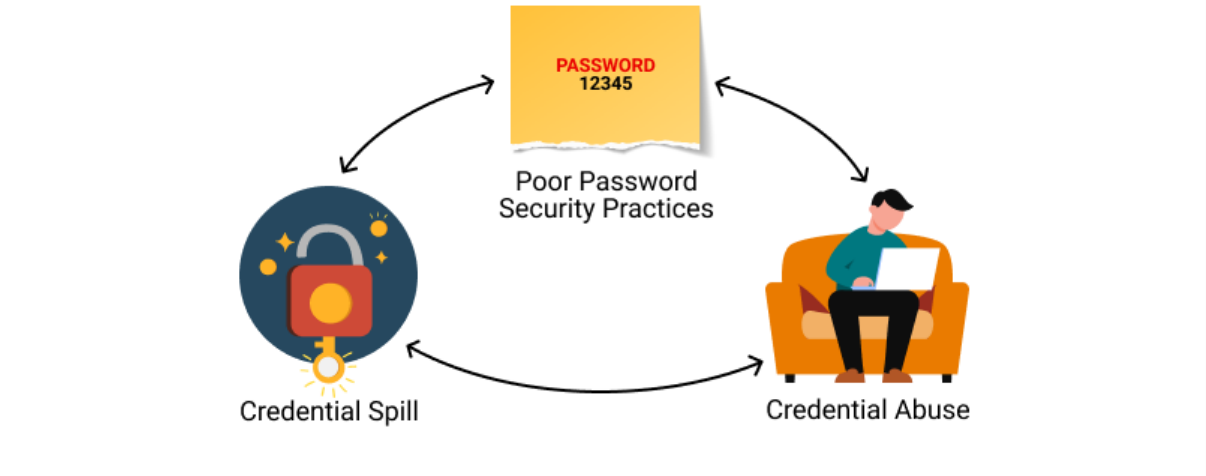
3) Vulnerability Name: Exposure of Sensitive Information
CWE-200
OWASP Category: A02:2021 – Cryptographic Failures
Description: Sensitive data such as passwords, tokens, or personal data is exposed in responses or logs.
Business Impact: Data leakage may lead to financial loss and legal issues.
Steps to Reproduce:

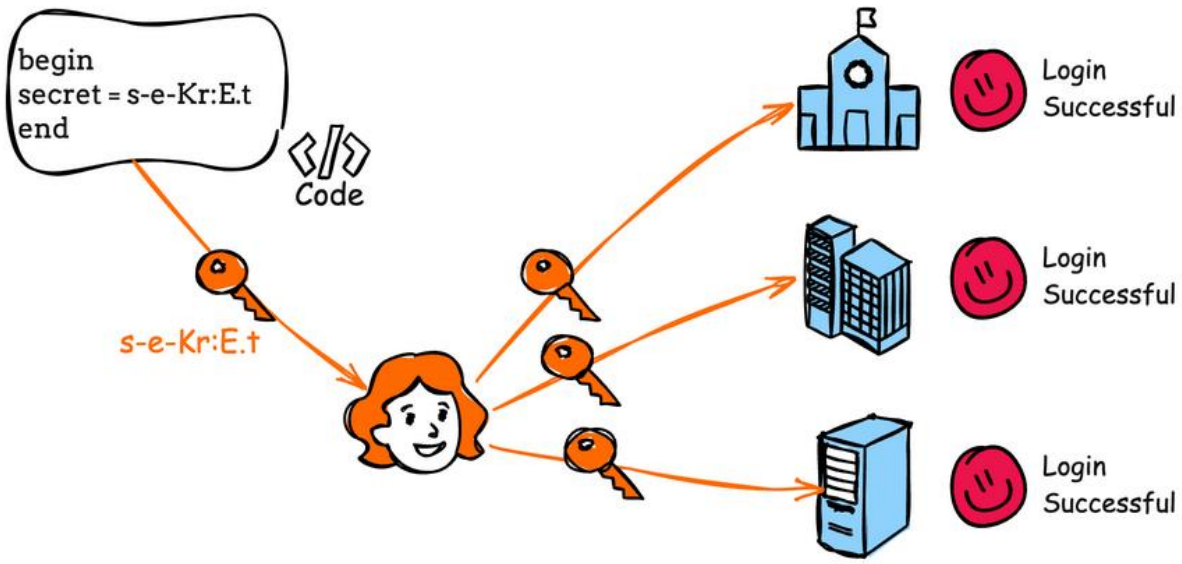
1. Inspect application responses or network traffic.
2. Sensitive data appears in plain text.



4) Vulnerability Name: Use of Hard-coded Credentials
CWE-798
OWASP Category: A07:2021 – Identification and Authentication Failures
Description: Credentials are embedded in application code or configuration files.
Business Impact: Attackers discovering these credentials can gain system access**.**
Steps to Reproduce:

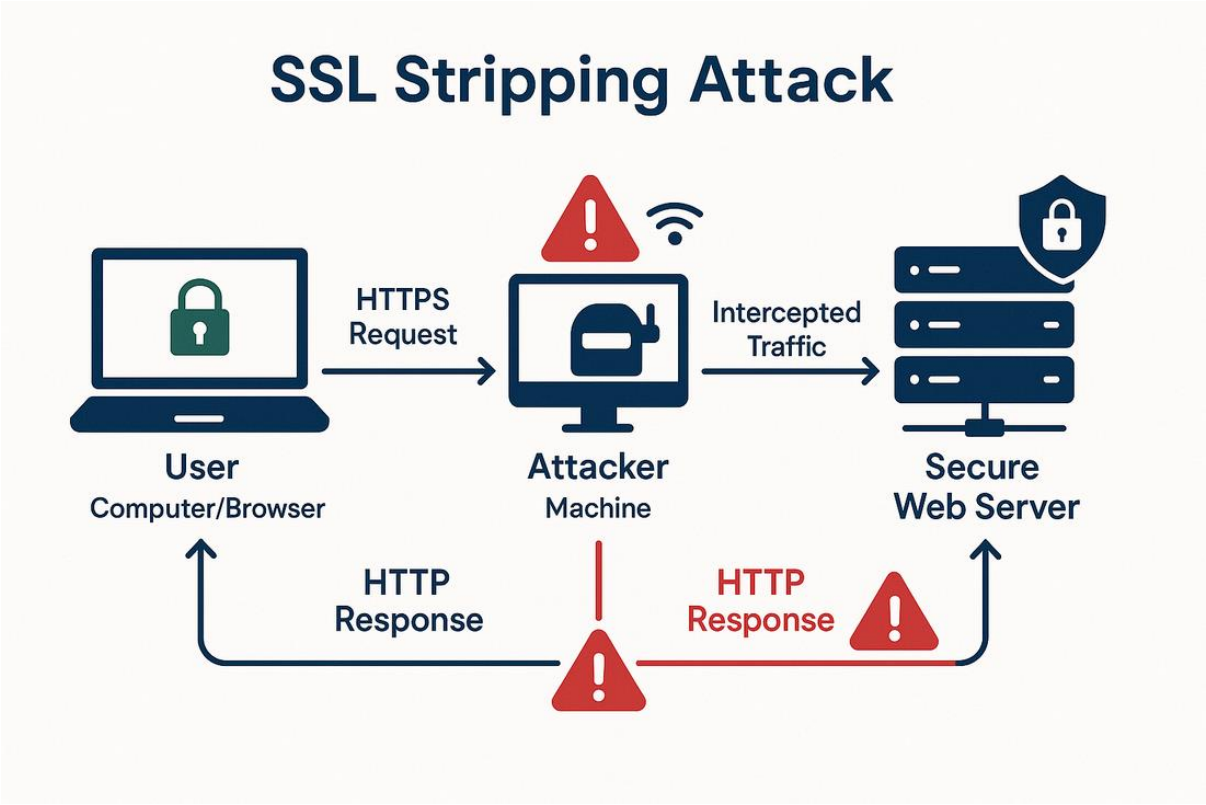
1. Review application source code or configuration files.
2. Hard-coded usernames and passwords are found.





5) Vulnerability Name: Improper Certificate Validation
CWE-295
OWASP Category: A02:2021 – Cryptographic Failures
Description: The application does not properly validate SSL/TLS certificates.
Business Impact: Attackers can perform Man-in-the-Middle attacks and intercept data.
Steps to Reproduce:

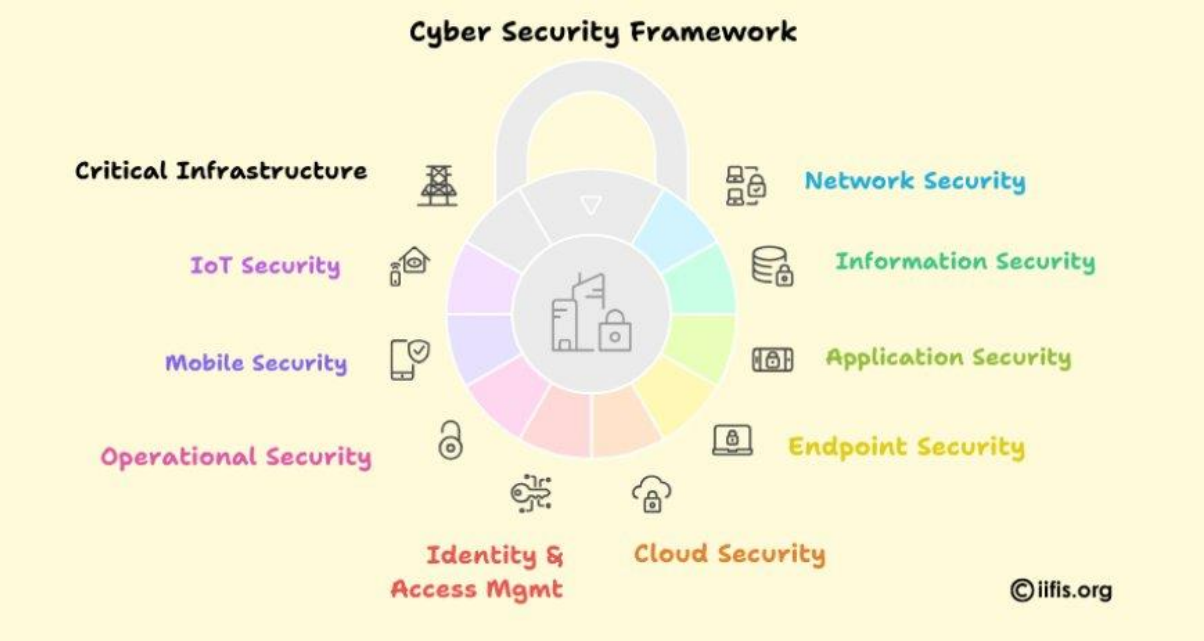
1. Intercept traffic using a proxy tool.
2. Application accepts invalid certificates.



---

6) Vulnerability Name: Missing Authentication for Critical Function
CWE-306
OWASP Category: A01:2021 – Broken Access Control
Description: Critical system functions are accessible without authentication.
Business Impact: Unauthorized users may manipulate sensitive system functions.
Steps to Reproduce:

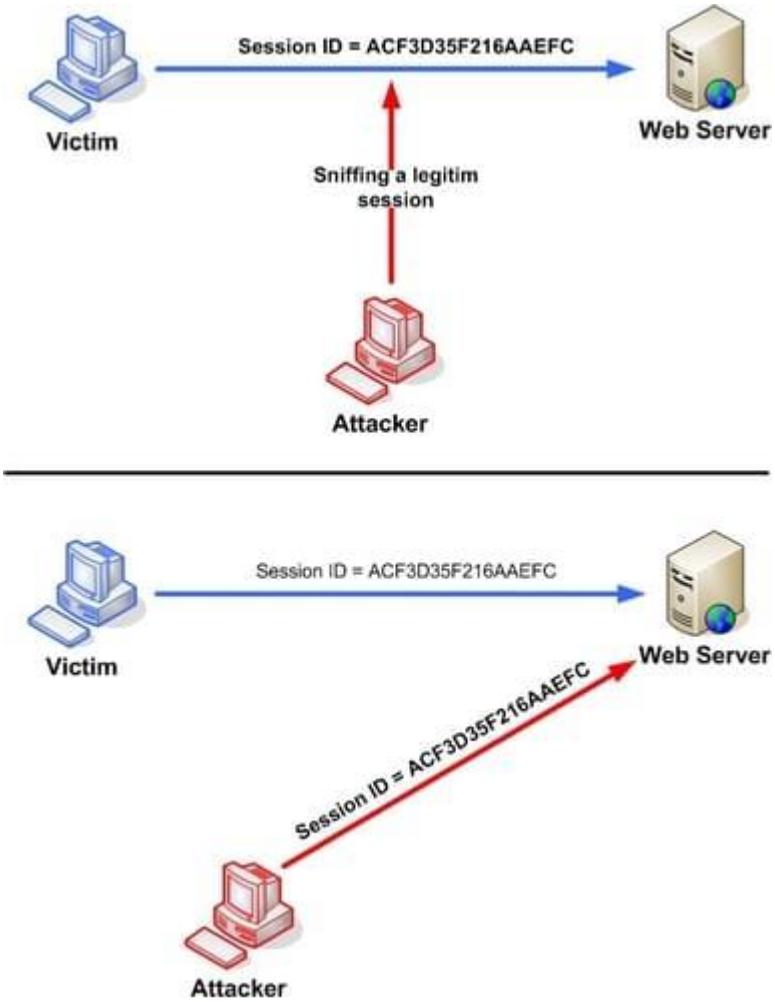
1. Access a critical endpoint directly through URL.
2. System allows access without login.



---

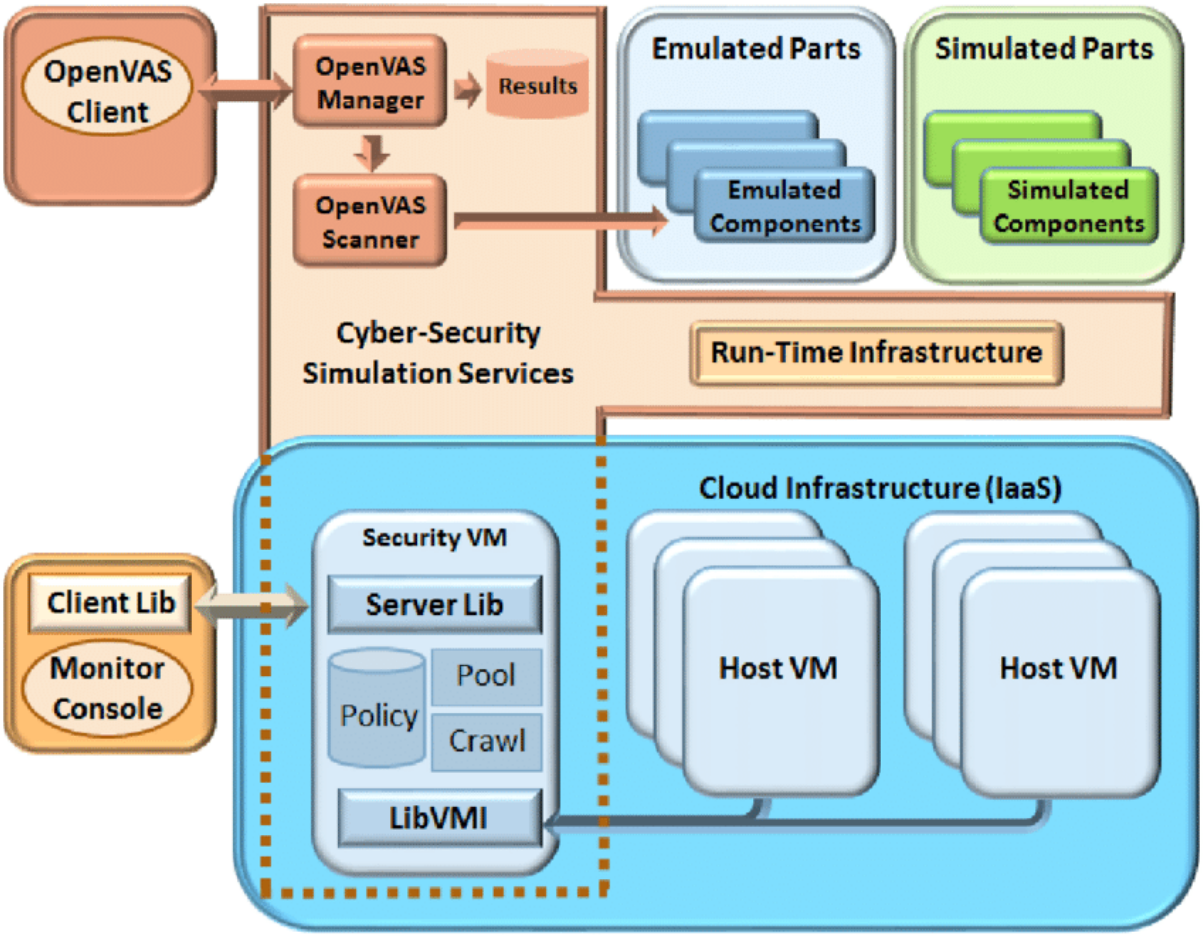
7) Vulnerability Name: Insufficient Session Expiration
CWE-613
OWASP Category: A07:2021 – Identification and Authentication Failures
Description: User sessions remain active for long periods without re-authentication.
Business Impact: Attackers may hijack active sessions and access systems.
Steps to Reproduce:

1. Log in to the application.
2. Leave the session inactive for a long time.
3. Session remains active.


Session ID = ACF3D35F216AAEFC
Victim
Web Server
Sniffing a legitim session
Attacker
Session ID = ACF3D35F216AAEFC
Victim
Web Server
Session ID = ACF3D35F216AAEFC
Attacker

8) Vulnerability Name: Improper Logging and Monitoring
CWE-778
OWASP Category: A09:2021 – Security Logging and Monitoring Failures
Description: Security events are not properly logged or monitored.
Business Impact: Security breaches may go undetected for a long time.
Steps to Reproduce:

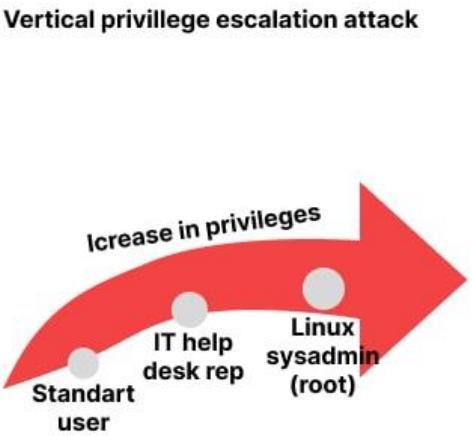
1. Perform suspicious activity.
2. Check logs and observe missing security records.



9) Vulnerability Name: Insufficient Authorization
CWE-862
OWASP Category: A01:2021 – Broken Access Control
Description: The system does not properly verify whether a user has permission to perform an action.
Business Impact: Privilege escalation and unauthorized system changes may occur.
Steps to Reproduce:

1. Log in as a standard user.
2. Attempt admin-level operations.
3. System allows the operation.

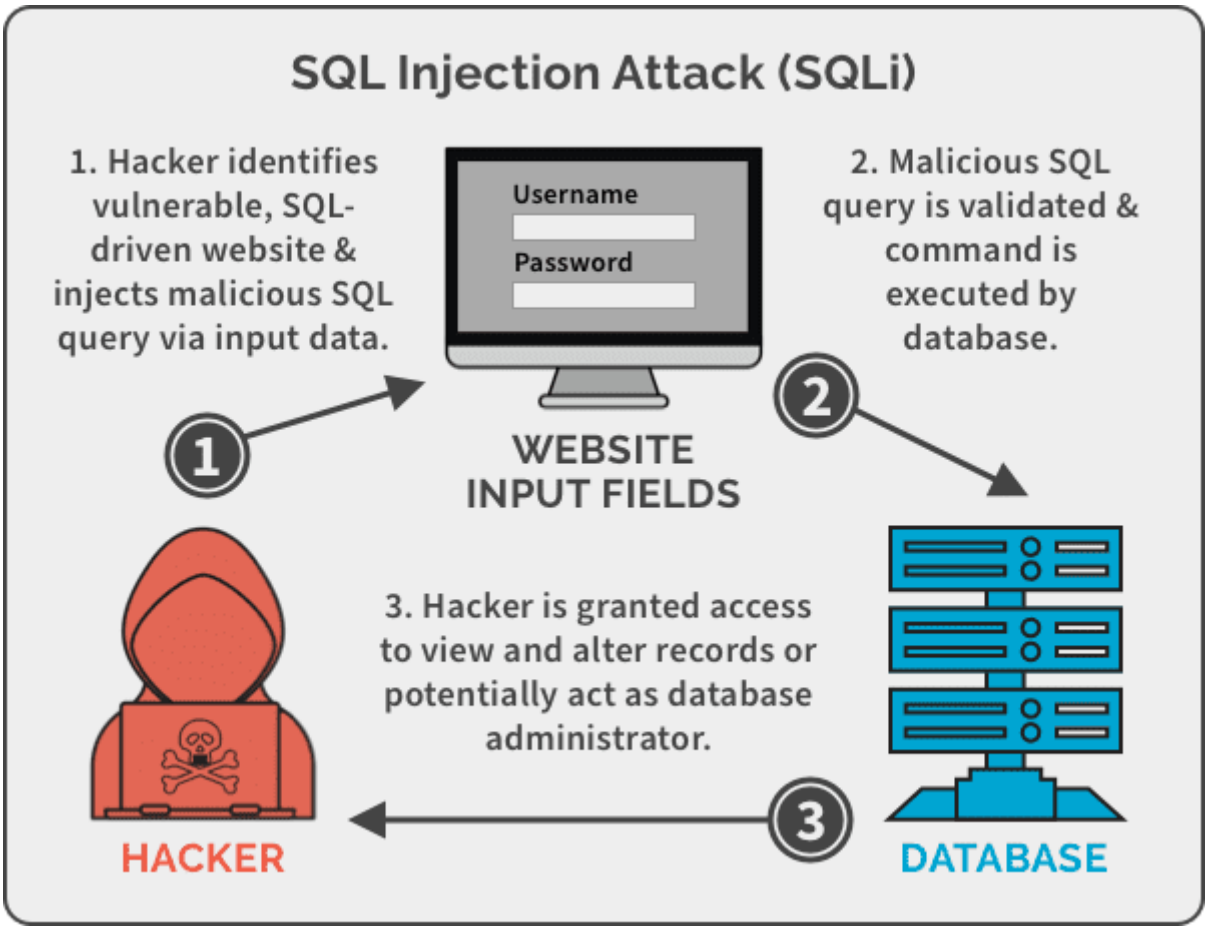
An internal horizontal escalation attack can occur between each of these accounts. Attackers can also achieve horizontal escalation by initially compromising one of these accounts.



A threat actor moves from standard user access to an IT Help Desk account before gaining Linux sysadmin (root) access. Each subsequent step represents more privileged access

10) Vulnerability Name: Improper Input Validation
CWE-20
OWASP Category: A03:2021 – Injection
Description: The application does not properly validate user inputs.
Business Impact: Attackers may inject malicious data leading to system compromise.
Steps to Reproduce:

1. Enter malicious input into a form field.
2. System processes the input without validation.



OVERVIEW

The integration of Zscaler with enterprise Identity Providers (IdPs) represents a fundamental shift in how organizations approach secure access to applications and resources. Traditional network security models relied on VPNs and perimeter-based defenses, which often granted excessive access and created lateral movement risks. By contrast, this project leverages Zscaler's Zero Trust Exchange platform to verify identity at the application layer rather than the network layer. The integration with leading IdPs such as Microsoft Entra ID, Okta, and on-premises Active Directory establishes a unified identity fabric across the organization. This ensures that users are authenticated consistently regardless of their location or device. The project eliminates the need for duplicate user directories and manual account management within Zscaler. It creates a seamless experience where users authenticate once and gain access to authorized resources. Security teams benefit from centralized control over authentication policies and user lifecycle management. The integration supports modern authentication standards including SAML, OIDC, and SCIM protocols. Ultimately, this foundation enables true Zero Trust security where identity becomes the primary control plane. Microsoft Entra ID integration serves as a cornerstone of this identity strategy for organizations heavily invested in the Microsoft ecosystem. The integration leverages SAML 2.0 to establish federated trust between Zscaler and Azure AD for seamless Single Sign-On. Users accessing Zscaler Internet Access or Zscaler Private Access portals are redirected to Azure AD for authentication. This allows organizations to enforce Azure AD Conditional Access policies during the authentication flow. Policies can require compliant devices, specific locations, or risk-based access controls before granting access to Zscaler. The integration extends beyond authentication to include automated user provisioning via the SCIM protocol. User accounts and group memberships are synchronized in real-time from Azure AD to Zscaler. This automation eliminates manual provisioning errors and ensures immediate deprovisioning when users leave the organization. Azure AD's extensive reporting and auditing capabilities provide visibility into authentication attempts. The result is a tightly integrated security posture that leverages Microsoft's identity capabilities to protect Zscaler-enforced resources. Okta integration provides a flexible and vendor-agnostic approach to identity management for Zscaler deployments. As a leading independent Identity Provider, Okta connects Zscaler to a wide ecosystem of applications and directories. The integration utilizes OpenID Connect (OIDC) for modern, API-friendly authentication to Zscaler services. This approach supports rich user context including profile attributes and group memberships for policy enforcement. Okta's Universal Directory serves as the authoritative source for user identities synchronized from various HR systems and directories. The Okta Integration Network (OIN) simplifies setup with pre-built connectors and configuration guides for Zscaler. Automated provisioning via SCIM ensures that user changes in Okta are reflected in Zscaler within minutes. Lifecycle management events such as user onboarding, role changes, and terminations trigger automatic updates in Zscaler. Okta's adaptive MFA policies add an additional security layer during Zscaler authentication requests. This integration delivers a seamless experience for users while providing administrators with centralized identity governance across all Zscaler services. On-premises Active Directory integration addresses scenarios where organizations are

not ready for full cloud identity migration. Many institutions maintain extensive on-premises infrastructure with complex group policies and nested organizational units. The Zscaler Authentication Bridge (ZAB) enables secure LDAP communication between Zscaler cloud services and on-premises AD. This lightweight connector sits behind the firewall and initiates outbound connections to Zscaler, eliminating the need for inbound firewall rules. User authentication requests are securely proxied through ZAB to validate credentials against the on-premises domain controllers. Group membership information is synchronized to Zscaler for use in policy definitions and access decisions. This approach preserves investments in existing Active Directory infrastructure while enabling cloud-delivered security. Organizations can maintain strict access controls based on on premises group memberships and organizational hierarchies.

Step-by-Step Explanation of How Nessus Works

Nessus connects to the target host using a variety of network protocols such as TCP, UDP, and ICMP. These protocols help the scanner communicate with the target system and check if it is reachable.

1. **Nessus sends a series of probes to the target host** to gather information about the system. These probes help identify the operating system, open ports, and services running on the target machine.
2. **Nessus runs a series of plugins** to test for vulnerabilities. Each plugin is designed to detect a specific security issue, such as missing patches, insecure configurations, or outdated software.
3. **Nessus analyzes the results and generates a detailed report.** The report includes:
    - The severity level of each vulnerability
    - Steps to reproduce the vulnerability
    - Recommended remediation methods to fix the issue

Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that help prioritize security improvements.

Benefits of Using Nessus

Here are some of the key benefits of using **Nessus**:

●Comprehensive vulnerability coverage: Nessus has thousands of plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

●Easy to use:
Nessus provides a user-friendly interface that allows administrators to easily configure and perform vulnerability scans.

●Detailed reporting:
Nessus generates comprehensive reports that include vulnerability severity, steps to reproduce the vulnerability, and recommended solutions.

●Scalability:
Nessus can scan different types of targets, including individual hosts, large networks, and web applications.

●Flexible scanning options:
Nessus allows users to run scans manually or schedule them automatically at specific times.

List of Vulnerabilities

S.No	Vulnerability Name	Severity	Plugin ID
1	TLS Version 1.0 Protocol Detection	Medium	104743
2	TLS Version 1.1 Protocol Deprecated	Medium	157288
3	SSL/TLS Diffie-Hellman Modulus ≤ 1024 Bits (Logjam)	Low	83875
4	ICMP Timestamp Request Remote Date Disclosure	Info	10114
5	Additional DNS Hostnames	Info	46180
6	Apache Tomcat Detection	Info	39446
7	Common Platform Enumeration (CPE)	Info	45590
8	Device Type Detection	Info	54615
9	HSTS Missing From HTTPS Server	Info	84502
10	HTTP Server Type and Version Disclosure	Info	10107

1. TLS Version 1.0 Protocol Detection

Severity: Medium
Plugin ID: 104743

This vulnerability indicates that the system supports **TLS version 1.0**, which is an outdated encryption protocol. TLS 1.0 has known security weaknesses and is considered insecure by modern security standards.

Risk:

Attackers may exploit weaknesses in the protocol to intercept encrypted communication.

Remediation:

Disable TLS 1.0 and enable more secure versions such as TLS 1.2 or TLS 1.3.

2. TLS Version 1.1 Protocol Deprecated

Severity: Medium

Plugin ID: 157288

This finding indicates that the server supports **TLS 1.1**, which is now deprecated. Many modern browsers and security frameworks no longer support this protocol.

Risk:

Using outdated encryption protocols may expose sensitive data to security risks.

Remediation:

Disable TLS 1.1 and use TLS 1.2 or TLS 1.3 for secure communication.

3. SSL/TLS Diffie-Hellman Modulus ≤ 1024 Bits (Logjam)

Severity: Low

Plugin ID: 83875

This vulnerability indicates that the server uses a **weak Diffie-Hellman key exchange with a modulus size of 1024 bits or less**.

Risk:

Attackers may perform cryptographic attacks to decrypt secure communications.

Remediation:

Use stronger encryption with Diffie-Hellman keys of at least 2048 bits.

4. ICMP Timestamp Request Remote Date Disclosure

Severity: Informational
Plugin ID: 10114

This finding shows that the system responds to **ICMP timestamp requests**, revealing the system's internal time.

Risk:
Attackers may use this information to gather system details and assist in network reconnaissance.

Remediation:
Disable ICMP timestamp responses on the server.

5. Additional DNS Hostnames

Severity: Informational
Plugin ID: 46180

The scan detected additional **DNS hostnames associated with the target system**.

Risk:
Attackers may use this information to identify other systems within the same infrastructure.

Remediation:
Limit DNS information exposure and secure DNS configuration.

6. Apache Tomcat Detection

Severity: Informational
Plugin ID: 39446

The scanner detected that the system is running **Apache Tomcat**, a popular web application server.

Risk:
If the server version is outdated or misconfigured, it may be vulnerable to known exploits.

Remediation:
Ensure Apache Tomcat is updated with the latest security patches.

7. Common Platform Enumeration (CPE)

Severity: Informational
Plugin ID: 45590

This result identifies the **Common Platform Enumeration (CPE)** information of the detected software.

Risk:
CPE data can help attackers identify the exact software version and search for known vulnerabilities.

Remediation:
Keep systems updated and minimize exposure of system information.

8. Device Type Detection

Severity: Informational
Plugin ID: 54615

Nessus detected the **type of device** being scanned, such as a server, router, or workstation.

Risk:
Device identification can help attackers plan targeted attacks.

Remediation:
Limit unnecessary network information disclosure.

9. HSTS Missing from HTTPS Server

Severity: Informational
Plugin ID: 84502

This vulnerability indicates that the **HTTP Strict Transport Security (HSTS)** header is missing.

Risk:
Without HSTS, attackers may perform **downgrade attacks** to force users into insecure HTTP connections.

Remediation:
Enable HSTS headers on the web server to enforce secure HTTPS connections.

10. HTTP Server Type and Version Disclosure

Severity: Informational
Plugin ID: 10107

The server reveals its **software type and version number** in HTTP responses.

Risk:
Attackers may use this information to identify known vulnerabilities associated with the specific server version.

Remediation:
Hide or mask server version information in the HTTP response headers.

STAGE-3

Title: Integrate Zscaler With Identity Providers(Idps)Such As Azure Ad,Okta,And Active Directory For Seamless Authentication And Authorization

This project outlines the strategy and implementation plan for integrating the Zscaler security platform with our organization's core Identity Providers (IdPs): Microsoft Entra ID (Azure AD), Okta, and on-premises Active Directory (AD). The primary objective is to create a seamless, secure, and automated framework for user authentication and authorization across all Zscaler services. By moving away from disparate local user management and leveraging these centralized identity sources, we aim to establish a true Zero Trust architecture where access is continuously verified based on user identity and context. This initiative will consolidate authentication into a single source of truth, enforce consistent security policies like Multi-Factor Authentication (MFA), and streamline the user experience through Single Sign-On (SSO). Ultimately, this integration will serve as the critical link between our identity infrastructure and our security enforcement point, ensuring that the right users have the right level of secure access to the internet and applications, regardless of their location.

What is Zscaler?

Zscalar is a cloud-based cybersecurity platform that helps organizations secure their internet traffic, applications, and users. It provides secure access to applications without exposing the internal network to the internet.

Zscaler works as a cloud security gateway that sits between users and applications. It inspects traffic, enforces security policies, and prevents cyber threats such as malware, ransomware, and unauthorized access.

The platform provides several services such as secure web gateway, cloud firewall, and Zero Trust Network Access. By using Zscaler, companies can replace traditional VPN-based security with a more scalable and secure cloud-based architecture.

Architecture of Zscaler

The architecture integrates **Zscaler** with enterprise Identity Providers such as **Microsoft Entra ID**, **Okta**, and **Active Directory** to enable secure Zero Trust access.

Users first attempt to access applications through the Zscaler platform. Zscaler redirects authentication requests to the configured Identity Provider using protocols like **SAML** or **OIDC**. The IdP verifies the user identity and applies security policies such as Multi-Factor Authentication (MFA) and Conditional Access.

After successful authentication, the IdP sends a secure token back to Zscaler, which then grants access only to authorized applications. User accounts and group memberships are automatically synchronized using **SCIM**, ensuring centralized identity management.

For organizations using on-premises Active Directory, the **Zscaler Authentication Bridge (ZAB)** securely connects the internal directory with Zscaler through outbound connections, enabling LDAP-based authentication without exposing internal infrastructure.

This architecture ensures **secure authentication, centralized identity control, automated user provisioning, and Zero Trust access to enterprise applications**.

Implementation Using Zscaler

The implementation begins by configuring **Zscaler** to integrate with enterprise Identity Providers for centralized authentication and authorization. Administrators first register Zscaler as an application in identity platforms such as **Microsoft Entra ID**, **Okta**, or **Active Directory**.

For **Microsoft Entra ID**, the integration is configured using **SAML-based Single Sign-On (SSO)**. Administrators create an enterprise application in Entra ID, configure the SAML settings, and exchange metadata between Entra ID and Zscaler. User accounts and group memberships are automatically synchronized using **SCIM provisioning**, enabling real-time updates and simplified user management.

For **Okta**, Zscaler is added as an application from the Okta Integration Network. Authentication is configured using **OpenID Connect (OIDC)** or SAML, and automated user provisioning is enabled through SCIM. Okta manages user lifecycle events such as onboarding, role changes, and deprovisioning, which are automatically reflected in Zscaler.

For organizations using on-premises infrastructure, integration with **Active Directory** is achieved through the **Zscaler Authentication Bridge (ZAB)**. The ZAB connector is installed within the internal network and securely connects to Zscaler using outbound communication. It performs **LDAP-based authentication** and synchronizes user group information for policy enforcement.

After completing these configurations, administrators define access policies in Zscaler based on user identity, group membership, and security requirements. This implementation enables **secure authentication, automated provisioning, centralized identity control, and Zero Trust access to enterprise resources**. 🔐

Benefits of Zscaler

Integrating **Zscaler** with Identity Providers such as **Microsoft Entra ID**, **Okta**, and **Active Directory** provides several advantages for organizations.

- **Enhanced Security:** Supports a Zero Trust model where user identity is verified before granting access to applications.

- **Single Sign-On (SSO):** Users authenticate once and securely access multiple applications without repeated logins.
- **Centralized Identity Management:** Administrators manage users, groups, and authentication policies from a single identity platform.
- **Automated User Provisioning:** Using protocols like SCIM, user accounts and permissions are automatically synchronized between the IdP and Zscaler.
- **Improved User Experience:** Provides seamless and secure access to resources from any location or device.
- **Stronger Access Control:** Enables advanced security features such as Multi-Factor Authentication (MFA) and conditional access policies.
- **Reduced Administrative Effort:** Eliminates manual account management and reduces configuration errors.

Conclusion

The integration of **Zscaler** with enterprise Identity Providers such as **Microsoft Entra ID**, **Okta**, and **Active Directory** provides a secure and efficient approach to managing user access. By implementing a **Zero Trust security model**, organizations can verify user identity before granting access to applications and resources.

This integration enables **Single Sign-On (SSO)**, centralized identity management, and automated user provisioning, reducing administrative effort and improving security. It also ensures consistent authentication policies across cloud and on-premises environments.

Overall, combining Zscaler with modern identity providers strengthens security, simplifies access management, and supports scalable, cloud-based enterprise infrastructure

Future scope

The integration of Zscaler with identity providers such as Microsoft Entra ID (formerly Azure AD), Okta, and Active Directory can be expanded to support more advanced security and automation features.

In the future, organizations can enhance this integration by implementing AI-based threat detection and behavioral authentication to identify suspicious access attempts. Advanced Zero Trust Network Access (ZTNA) capabilities can provide more granular, application-level

access control. Integration with additional cloud platforms and SaaS applications can further extend secure access across the enterprise environment.

Organizations may also adopt passwordless authentication, stronger multi-factor authentication (MFA) methods, and automated compliance monitoring to improve security and user experience. These improvements will help create a more scalable, intelligent, and identity-driven security architecture for modern enterprises.